Lab 3— POST-INCIDENT ANALYSIS

TABLE OF CONTENTS

#	Section
1	ROOT CAUSE ANALYSIS (5 WHYS METHOD)
2	FISHBONE (ISHIKAWA) DIAGRAM
3	SOC METRICS: MTTD AND MTTR CALCULATION
4	Lessons Learned

Tools: Google Sheets, Draw.io | Date: 01 April 2026

1. ROOT CAUSE ANALYSIS (5 WHYS METHOD)

1.1 What is the 5 Whys Method?

The 5 Whys is a root cause analysis (RCA) technique developed by Sakichi Toyoda and widely adopted in SOC incident investigations. It involves asking 'Why?' repeatedly — typically five times — until the fundamental root cause is uncovered. In cybersecurity, this method helps analysts move beyond surface-level symptoms to identify and fix the systemic vulnerabilities that allowed an incident to occur

1.2 Tools and Platform Setup — Google Sheets:

Step	Action	Detailed Instructions
1	Open Google Sheets	Browser → Navigate to https://sheets.google.com
2	Create New File	Click the '+' Blank button (top-left) or press Shift+S
3	Rename File	Click 'Untitled spreadsheet' at top → Type: RCA_Phishing_30032026
4	Rename Sheet Tab	Double-click 'Sheet1' tab at bottom → Type: 5-Whys RCA
5	Set Column Widths	Right-click col B → Resize → 280px; Right-click col C → Resize → 320px
6	Freeze Header Row	View menu → Freeze → 1 row (keeps header visible while scrolling)
7	Enable Alternating Colors	Format menu → Alternating colors → Choose a style → Done

1.3 Step-by-Step Instructions:

STEP	**Step 1 — Create Header Row:** Click cell A1. Type across columns A to F: # | Why Question | Answer/Finding | Evidence/Source | Responsible Team | Action Item. These are your six column headers.
INFO	**Step 2 — Format Header Row:** Select Row 1 (click row number 1). Apply Bold (Ctrl+B). Set Background Color to Dark Navy (#0A1628) and Font Color to White. Set font size to 10pt.
NOTE	**Step 3 — Add Incident Metadata Block:** In rows 1-6 (before your table), add incident context: Incident ID, Date (30-03-2026), Source IP (10.0.2.20), Severity (HIGH), Analyst Name, Detection Time. Merge cells B1:D1 for wider values.
DETAIL	**Step 4 — Enter the 5 Whys Data: Starting from row 8, enter each Why-Answer pair in separate rows. Number them 1-5 in column A. Include Evidence Source, Responsible Team, and an Action Item for each level.**
INFO	**Step 5 — Add Data Validation: Select column E (Responsible Team). Click Data menu Data Validation Criteria: List of items Enter: SOC, IT Infrastructure, IT Security, Management, CISO, Compliance Save.**

CRITICAL	**Step 6 — Apply Conditional Formatting: Select Column F (Action Items) ⍰ Format ⍰ Conditional Formatting. Add three rules: 'Text contains Deploy' = Red; 'Text contains Schedule' = Yellow; 'Text contains training' = Green.**

1.4 Complete 5 Whys Table — Phishing Incident (Source IP: 10.0.2.20)

The following is the full Root Cause Analysis for the phishing attack on 30-03-2026. Each 'Why' level digs deeper into the systemic failure, from user behaviour down to policy gaps

#	Why Question	Answer / Finding	Evidence / Source	Responsible Team	Action Item
1	**Why was the phishing email opened?**	User clicked malicious link in email disguised as IT Support notification	Email logs, User incident report, SIEM alert INC-001	SOC / End User	Mandatory quarterly phishing simulation and security awareness training
2	**Why was the malicious link clicked without verification?**	Email passed spam filter — weak email filtering; no Advanced Threat Protection	Email gateway config logs, MX Toolbox SPF/DKIM check results	IT Infrastructure	Harden email filtering: enforce SPF, DKIM, DMARC; deploy ATP sandboxing
3	**Why did the email filter fail to block the phishing email?**	No ATP or email sandboxing was enabled on the email gateway	Email gateway vendor config review, Security audit report Q1 2026	IT Security	Deploy Microsoft Defender ATP or Proofpoint email sandbox — 30 days
4	**Why was no Advanced Threat Protection enabled?**	Budget constraints and no formal security policy mandating ATP deployment	Budget approval records, IT Security Policy document v2.1	Management / CISO	Update InfoSec Policy to mandate ATP; allocate budget in Q2 2026
5	**Why was there no formal security policy requiring ATP?**	Post-incident review process was not enforced; no scheduled policy audit cycle	Audit logs, policy version history, Change Management records	CISO / Compliance	Establish quarterly policy review cycle; assign Compliance Officer accountability

1.5 Google Sheets Formulas and Implementation Code:

```
// ====== GOOGLE SHEETS — 5 WHYS RCA SPREADSHEET SETUP ======
// File name: RCA_Phishing_30032026 | Sheet: 5-Whys RCA
// INCIDENT METADATA BLOCK (Rows 1-6):
A1: "INCIDENT RCA REPORT" B1: "Phishing Attack — INC-2026-0330-001"
A2: "Incident Date:" B2: "30-03-2026"
A3: "Source IP:" B3: "10.0.2.20"
A4: "Analyst:" B4: "[Your Name / SOC Team]"
```

A5: "Severity:" B5: "HIGH"
A6: "Detection Time:" B6: "11:00 AM IST"
// TABLE HEADERS (Row 8):
A8: "#" B8: "Why Question" C8: "Answer/Finding"
D8: "Evidence/Source" E8: "Responsible Team" F8: "Action Item"
// DATA VALIDATION for Column E (Responsible Team):
// Data > Data Validation > Criteria: List of items:
// SOC, IT Infrastructure, IT Security, Management, CISO, Compliance
// SUMMARY COUNTS (Row 16 onwards):

A16: "Total Why Levels:" B16: =COUNTA(A9:A13)
A17: "Total Action Items:" B17: =COUNTA(F9:F13)
A18: "SOC-owned items:" B18: =COUNTIF(E9:E13,"SOC*")
A19: "CISO-owned items:" B19: =COUNTIF(E9:E13,"CISO*")
A20: "IT Security items:" B20: =COUNTIF(E9:E13,"IT Security")

2. What is a Fishbone Diagram?

A Fishbone Diagram (also called an Ishikawa or Cause-and-Effect Diagram) is a visual tool that maps all potential causes of a problem. The diagram resembles a fish skeleton: the 'head' represents the problem/effect and the 'bones' branching off the spine represent categories of causes. In SOC incident analysis, it organizes contributing factors across six standard categories: People, Process, Technology, Environment, Management, and Measurement.

2.1 Tools and Platform Setup — Draw.io:

Step	Action	Detailed Instructions
1	Open Draw.io	Browser → https://app.diagrams.net
2	Storage Choice	Click 'Decide later' — saves locally or to Google Drive
3	New Diagram	Select 'Blank Diagram' → Click Create
4	Set Landscape	File → Page Setup → Orientation: Landscape → Apply
5	Enable Grid	View → Grid (Ctrl+Shift+G) — helps align shapes
6	Reset Zoom	View → Reset Zoom (Ctrl+Shift+H) — see full canvas
7	Rename File	File → Rename → Fishbone_Phishing_30032026

2.2 Step-by-Step Construction Guide

STEP	**Step 1 — Draw the Main Spine:** From the Draw.io left toolbar, drag an Arrow/Line shape horizontally across the canvas (left to right). Right-click on it → Edit Style → set strokeWidth=4 and strokeColor=#000000. This thick horizontal arrow is the 'spine' of the fish.
CRITICAL	**Step 2 — Add the Effect Box (Fish Head):** At the RIGHT end of the spine, add a Rectangle shape. Label it: 'EFFECT: User Credentials Compromised | Phishing Attack | IP: 10.0.2.20 | 30-03-2026'. Style: fillColor=#FF0000; fontColor=#FFFFFF; fontStyle=1 (Bold).

INFO	**Step 3 — Draw Upper Category Bones:** Draw 3 diagonal lines angling from upper-left DOWN to meet the spine. Label the box at the top of each: PEOPLE (far left), PROCESS (middle), TECHNOLOGY (right). Each diagonal connects to the spine.
NOTE	**Step 4 — Draw Lower Category Bones: Draw 3 diagonal lines angling from lower-left UP to meet the spine. Label boxes: MANAGEMENT (far left), ENVIRONMENT (middle), MEASUREMENT (right). Mirror the upper structure.**
DETAIL	**Step 5 — Add Sub-Cause Mini-Bones: From each main diagonal bone, draw smaller horizontal lines branching off. At each end, add a small text label — one specific cause per line (e.g., 'No phishing training', 'No ATP enabled', 'No MFA enforced').**
STEP	**Step 6 — Color Code Categories: Right-click each category box ⍰ Edit Style ⍰ set fillColor: People=Blue (#1565C0), Process=Green (#2E7D32), Technology=Orange (#E65100), Management=Purple (#4A148C), Environment=Amber (#F57F17), Measurement=Red (#C62828).**
INFO	**Step 7 — Add Diagram Title: Add a Text shape at the top of the canvas. Label it: 'Fishbone Diagram — Phishing Incident Analysis | Source IP: 10.0.2.20 | Date: 30-03-2026 | Analyst: SOC Team'.**

2.3 Cause Categories and Full Sub-Cause Details:

The following table lists all six categories with specific sub-causes for the phishing incident. Each sub-cause becomes a mini-bone in your Draw.io diagram:

Category	Color	Sub-Causes (Each becomes a Mini-Bone in Draw.io)	Links to Why #
PEOPLE	#1565C0 Blue	1. No phishing simulation training conducted 2. User ignored email sender warning signs 3. No security awareness about malicious links 4. No clear procedure to report suspicious emails	**Why #1**
PROCESS	#2E7D32 Green	1. No mandatory email verification policy 2. No Multi-Factor Authentication (MFA) enforced 3. No incident response drill / tabletop exercise 4. Missing escalation path for email threats	**Why #2**
TECHNOLOGY	#E65100 Orange	1. Weak email filter — SPF/DKIM/DMARC not fully configured 2. No ATP or email sandboxing enabled 3. No Endpoint Detection and Response (EDR) on workstation 4. Outdated antivirus signatures	**Why #3**
MANAGEMENT	#4A148C Purple	1. No budget allocated for email security tools 2. No scheduled security audit cycle 3. No CISO directive issued for ATP deployment 4. No accountability framework for policy compliance	**Why #4**

ENVIRONMENT	#F57F17 Amber	1. Employee on unsecured home network 2. No mandatory VPN usage policy 3. Corporate device used for personal browsing 4. No network segmentation for remote workers	**Why #2 and #4**
MEASUREMENT	#C62828 Red	1. No MTTD/MTTR KPI tracking in place 2. No phishing click-rate metric measured 3. No alert threshold defined in SIEM 4. No monthly SOC performance reporting cycle	**Why #5**

2.4 Draw.io XML Import Code

DRAW.IO XML — Copy and paste into: Extras > Edit Diagram > Replace all content
The XML structure below defines the complete Fishbone Diagram:
Root Elements:
mxCell id=0 and id=1 (required base cells)
SPINE (id=2):
Style: endArrow=block; endFill=1; strokeWidth=4; strokeColor=#000000
From: x=60, y=300 → To: x=820, y=300
EFFECT BOX — Fish Head (id=3):

Value: "EFFECT: User Credentials Compromised | IP:10.0.2.20 | 30-03-2026"
Style: rounded=1; fillColor=#FF0000; fontColor=#FFFFFF; fontStyle=1; fontSize=11
Position: x=820, y=262, width=220, height=76
UPPER BONE 1 — PEOPLE (id=4):
Style: fillColor=#1565C0; fontColor=#FFFFFF; fontStyle=1; fontSize=12
Position: x=100, y=130, width=130, height=44
Diagonal line: (165,152) to (280,300) — strokeColor=#1565C0; strokeWidth=2
Sub-cause A (id=6): "No phishing simulation training" — x=70, y=90
Sub-cause B (id=7): "User ignored email warning signs" — x=50, y=58
UPPER BONE 2 — PROCESS (id=8):
Style: fillColor=#2E7D32; fontColor=#FFFFFF; fontStyle=1; fontSize=12
Position: x=360, y=130, width=130, height=44
Diagonal line: (425,152) to (500,300) — strokeColor=#2E7D32; strokeWidth=2
Sub-cause A (id=10): "No MFA enforcement" — x=330, y=90
Sub-cause B (id=11): "No email verify policy" — x=310, y=58
UPPER BONE 3 — TECHNOLOGY (id=12):
Style: fillColor=#E65100; fontColor=#FFFFFF; fontStyle=1; fontSize=12
Position: x=590, y=130, width=140, height=44
Diagonal line: (660,152) to (700,300) — strokeColor=#E65100; strokeWidth=2
Sub-cause A (id=14): "No ATP / Email Sandboxing" — x=560, y=90
Sub-cause B (id=15): "Weak SPF/DKIM/DMARC config" — x=545, y=58
LOWER BONE 1 — MANAGEMENT (id=16):
Style: fillColor=#4A148C; fontColor=#FFFFFF; fontStyle=1; fontSize=12
Position: x=100, y=380, width=140, height=44
Diagonal line: (170,422) to (280,300) — strokeColor=#4A148C; strokeWidth=2
Sub-cause A (id=18): "No ATP budget approved" — x=75, y=435
Sub-cause B (id=19): "No policy audit cycle" — x=60, y=468
LOWER BONE 2 — ENVIRONMENT (id=20):
Style: fillColor=#F57F17; fontColor=#FFFFFF; fontStyle=1; fontSize=12
Position: x=355, y=380, width=140, height=44
Diagonal line: (425,422) to (500,300) — strokeColor=#F57F17; strokeWidth=2
Sub-cause A (id=22): "Unsecured home network (no VPN)" — x=320, y=435
LOWER BONE 3 — MEASUREMENT (id=23):
Style: fillColor=#C62828; fontColor=#FFFFFF; fontStyle=1; fontSize=12
Position: x=590, y=380, width=140, height=44
Diagonal line: (660,422) to (700,300) — strokeColor=#C62828; strokeWidth=2

Sub-cause A (id=25): "No MTTD/MTTR KPIs tracked" — x=565, y=435
Sub-cause B (id=26): "No phishing click-rate metric" — x=550, y=468
TITLE TEXT (id=27):
Value: "Fishbone Diagram: Phishing Incident | IP: 10.0.2.20 | 30-03-2026"
Style: fontSize=14; fontStyle=1; align=center
Position: x=150, y=10, width=700, height=36

3. SOC METRICS: MTTD AND MTTR CALCULATION:

3.1 SOC Metric Definitions:

Metric	Full Name	Definition	Formula	Benchmark
MTTD	Mean Time To Detect	Time from incident start to SOC detection	Detection Time - Start Time	< 1 hour
MTTR	Mean Time To Respond	Time from detection to full resolution	Resolution Time - Detection Time	< 4 hours
MTTI	Mean Time To Investigate	Time from alert triage to incident confirmation	Investigation End - Triage Start	< 30 minutes
MTTC	Mean Time To Contain	Time from confirmation to threat containment	Containment Time - Confirm Time	< 2 hours

3.2 Mock Incident Timeline:

Event Description	Action Taken	Team	Status
Phishing email received — IP 10.0.2.20 — spoofed IT domain	No action — email passed filter	Email Gateway	UNDETECTED
User clicks malicious link — credentials entered on fake portal	No alert triggered	End User	COMPROMISED
SIEM receives failed login alert from unusual IP 10.0.2.20	Alert queued — not triaged	SIEM Auto	ALERT QUEUED
SOC Analyst notices anomalous SIEM alert during routine review	Analyst begins investigation	SOC L1	INVESTIGATING
Incident DETECTED — Ticket INC-2026-0330-001 raised	IR process initiated	SOC L1+L2	DETECTED
Affected user account disabled — password reset initiated	Containment executed	SOC L2+IT	CONTAINED
Malicious IP 10.0.2.20 blocked at firewall — email rule updated	Threat blocked at perimeter	SOC L2+Network	BLOCKED
Incident RESOLVED — systems verified clean — ticket closed	Post-incident docs started	SOC L3+CIS	RESOLVED

		O	

3.3 Metrics Calculation:

Metric	Formula	Values Used	Result
MTTD (Time to Detect)	Detection Time minus Incident Start Time	11:00 AM minus 09:00 AM	2 Hours (120 min)
MTTR (Time to Respond)	Resolution Time minus Detection Time	01:00 PM minus 11:00 AM	2 Hours (120 min)
Total Incident Duration	Resolution Time minus Incident Start Time	01:00 PM minus 09:00 AM	4 Hours (240 min)
Time to Contain	Containment Time minus Detection Time	11:30 AM minus 11:00 AM	30 Minutes
Time to Block Threat	Block Time minus Detection Time	12:00 PM minus 11:00 AM	1 Hour (60 min)

3.4 Google Sheets Formula Implementation:

```
// ====== GOOGLE SHEETS — SOC METRICS DASHBOARD SETUP ======
// Sheet Tab Name: "SOC Metrics Dashboard"
// HEADER ROW (Row 1):
A1: Incident ID B1: Start Time C1: Detect Time
D1: Resolve Time E1: MTTD (hrs) F1: MTTR (hrs)
G1: Total TTR H1: Severity I1: Status
// DATA ROW 2 — Mock Phishing Incident:
A2: INC-2026-0330-001
B2: 9:00 AM (Format cells B:D as: Time → HH:MM AM/PM)
C2: 11:00 AM
D2: 1:00 PM
E2: =TEXT(C2-B2,"[h]:mm") // Result: 2:00 (2 hours MTTD)
F2: =TEXT(D2-C2,"[h]:mm") // Result: 2:00 (2 hours MTTR)
G2: =TEXT(D2-B2,"[h]:mm") // Result: 4:00 (4 hours total)
H2: HIGH
I2: RESOLVED
// ADDITIONAL INCIDENT ROWS (for MEAN calculation):
A3: INC-2026-0328-001 B3: 10:00 AM C3: 10:45 AM D3: 2:00 PM
E3: =TEXT(C3-B3,"[h]:mm") F3: =TEXT(D3-C3,"[h]:mm")
// AVERAGES SECTION (Row 12+):
A12: "AVERAGE MTTD:" B12: =AVERAGE(E2:E10)
A13: "AVERAGE MTTR:" B13: =AVERAGE(F2:F10)
A14: "MAX MTTD:" B14: =MAX(E2:E10)
A15: "MIN MTTR:" B15: =MIN(F2:F10)
A16: "Total Incidents:" B16: =COUNTA(A2:A10)
// CONDITIONAL FORMATTING for MTTD column (E2:E10):
// Format > Conditional formatting > Add rule:
// Rule 1: Greater than 02:00 -> Red fill (exceeds 2hr benchmark)
```

// Rule 2: Between 01:00-02:00 -> Yellow fill (approaching benchmark)
// Rule 3: Less than 01:00 -> Green fill (within best-practice)

3.5 Dashboard Chart Setup in Google Sheet

Step	Action	Settings to Apply
1	Select Data Range	Select cells A1:F10 (all incident data with headers)
2	Insert Chart	Insert menu → Chart — Chart editor opens on right
3	Choose Chart Type	Clustered Bar Chart (best for MTTD vs MTTR side-by-side)
4	Configure Axes	X-Axis: Incident ID | Series 1: MTTD | Series 2: MTTR
5	Add Title	Customize tab → Chart title: 'SOC Metrics — March 2026'
6	Color Coding	MTTD bars: Blue #1565C0 | MTTR bars: Green #2E7D32
7	Add Data Labels	Customize → Series → check 'Data labels' to show values
8	Add Benchmark Line	Series → Add series → Enter benchmark: MTTD=1hr, MTTR=2hr
9	Move Chart	3-dot menu → Move to own sheet → Name: 'Metrics Chart'
10	Export	Right-click chart → Download → PNG or PDF

Lessons Learned — Phishing Incident (30-03-2026)

#	Lesson Learned	Category	Priority	Recommended Action
1	Email security controls were insufficient — ATP was not deployed despite known risk	Technology	CRITICAL	Deploy Microsoft Defender ATP or Proofpoint — Timeline: 30 days
2	Users had no recent phishing training — click rate high	People	HIGH	Mandatory quarterly phishing simulation via KnowBe4 or Proofpoint
3	SIEM alert queued 1.5 hours before triage — MTTD was 2hrs vs 1hr benchmark	Process	HIGH	Implement 24/7 SOC coverage with automated SOAR alert prioritization
4	No MFA enforced — credential compromise led to full account takeover	Technology	CRITICAL	Enforce MFA on all systems via Azure AD Conditional Access — immediate
5	No formal InfoSec policy requiring ATP, MFA, or training	Management	HIGH	Rewrite Information Security Policy — CISO sign-off by 30 April 2026
6	Remote worker on unprotected home network — no VPN enforced	Environment	MEDIUM	Enforce mandatory VPN for all remote sessions — update policy
7	No MTTD/MTTR tracking — SOC performance unmeasured	Measurement	MEDIUM	Implement SOC KPI dashboard — monthly reviews with CISO

Document Title	SOC Post-Incident Analysis — Practical Application Documentation
Incident Reference	INC-2026-0330-001 | Phishing Attack | Source IP: 10.0.2.20
Incident Date	30 March 2026
Prepared By	SOC Analyst Team | Prayagraj, Uttar Pradesh, India
Tools Used	Google Sheets (RCA + Metrics Dashboard) | Draw.io (Fishbone Diagram)
Modules	Module 1: 5 Whys RCA | Module 2: Fishbone Diagram | Module 3: MTTD/MTTR
Classification	CONFIDENTIAL — SOC Internal Use Only
Review Date	30 April 2026